

B-B-06 招待トークンが使い回せてしまう

概要

招待メールに含まれる招待 URL(トークン)が、一度オンボーディングを完了した後も使い回せてしまう。本来は一度使った招待 URL は使用済みになって再利用できないはずだが、同じ URL から何度でもオンボーディングをやり直せる(名前・パスワードの再設定が繰り返せる)状態になっている。

再現手順

前提: 有効な招待 URL を 1 通受け取っている(招待中ユーザー)。

1. 招待 URL を開き、オンボーディング(名前・パスワード設定等)を完了する
2. 同じ招待 URL をもう一度開く
3. → 使用済みエラーにならず、オンボーディング画面が再び開けてしまい、再度登録内容を上書きできる

期待する結果

一度オンボーディングを完了した招待 URL に再アクセスすると、使用済みとして拒否され(410)、オンボーディングを再実行できない。

実際の結果

オンボーディング完了後も招待が「未使用」の状態のまま残るため、同じ URL から何度でもオンボーディングが可能で、登録内容を繰り返し上書きできてしまう。

メタ情報

項目	値
チケット ID	B-B-06
Feature 連番	auth-01
Feature	auth(招待 → オンボーディング)
種別	Bug
サブカテゴリ	セキュリティ(トークン管理)

項目	値
難易度	Basic
依存チケット	(なし)